

DI-FCT-UNL

Computer Systems Security

Segurança de Sistemas de Computadores

MSc on Computer Science and Engineering

Mestrado em Engenharia Informática

1º Sem, 2025/2026

1. Introduction: initial security concepts and principles

- How to define a secure system ?
- Security objectives and properties in computer systems security
- Systematic approach in designing secure systems
- The role of security frameworks
- OSI X.800 Framework

Suggested Readings

- Review the slides ...
- [CS] W. Stallings, L. Brown, Computer Security – Principles and Practice, Person, Ch.1 - Overview
- [NSE] W. Stallings, Network Security Essentials – Applications and Standards, Ch.1 – Introduction



What is a Secure System ?

How to define a secure system
(Systems: Computer Systems and Networks)

...

How to define a “Secure System” ?

- A system that was never revealed to be insecure or unsafe in its use
- A system that always performed correctly
- A system that never revealed vulnerabilities
- A system that has never been attacked

...

... Intrinsically all these definitions say that ...

THERE ARE NO SECURE SYSTEMS ! IMPOSSIBILITY !

☹ ... Why ?

☹ ... So these definitions are not interesting ..!

Computer security definition*

- Combined art, science and engineering practice of protecting computer-related assets from unauthorized actions (**malicious actions or attacks**) and their consequences (**security incidents**), either by preventing such actions or detecting and then recovering from them.
 - *) Definition in P. van Oorschot, Computer Security and the Internet, Chap.1 – Security Concepts and Principles, 2021
- Computer security **aims to protect data, computer hardware and software plus related communications networks, and physical-world devices and elements they control**, from intentional misuse by unauthorized parties—i.e., access or control by entities other than the legitimate owners or authorized agents
- **Mechanisms** protecting computers against unintentional damage or mistakes, or that fall under the categories of **reliability and redundancy**, are also at times essential for overall computer security
- The overall **goal of computer security is to support computer-based services by providing security properties that help deliver on expectations.**

Computer Systems and Networks Security Dimensions

Computer Systems Security (as defined by NIST)¹

The protection (measures and controls) afforded to an automated information system in order to attain the applicable **objectives of ensuring security properties** of information system resources, including hardware, software, firmware, information/data and communications.

Facets or Dimensions:

Network Security

(Communication protocols and services supporting data transfers)

Computer Systems Security

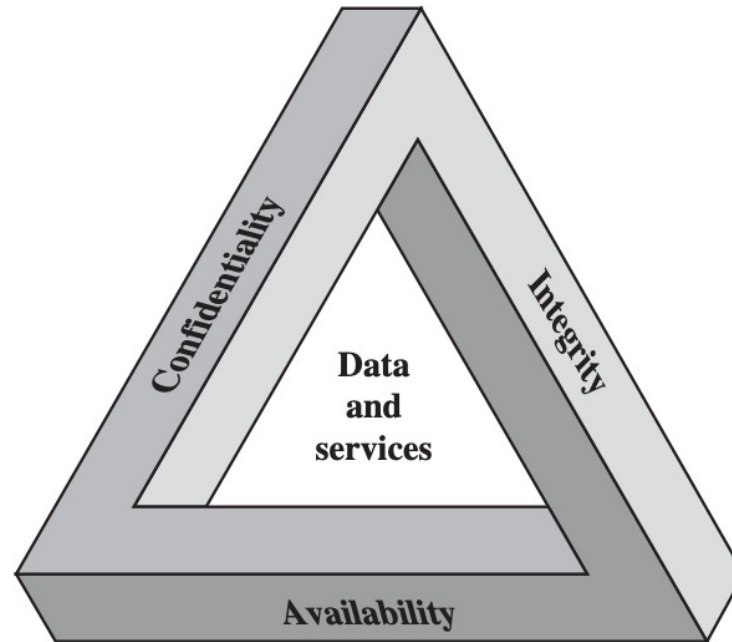
(SW/HW stacks and related resources, including physical resources)

1. NIST: <https://www.nist.gov/>
in NISTIR 7298 – Glossary of Key Information Security Terms, July/2019,
also in “Computer Security Principle

How to define the Security Objectives and Security Properties

- Using well-established/well-known conceptual bases, definitions, concepts, terminology and standards
- Relevance of Security Frameworks
 - Structured set of guidelines together with standards, and best practices, providing a systematic approach to identifying, assessing, and addressing security risks, ensuring the protection of critical assets, such as data, systems, and networks, from threats like cyberattacks or data breaches.

How to define the **objectives of preserving security properties** ?



C.I.A Triad

NISTIR 7298, 2013

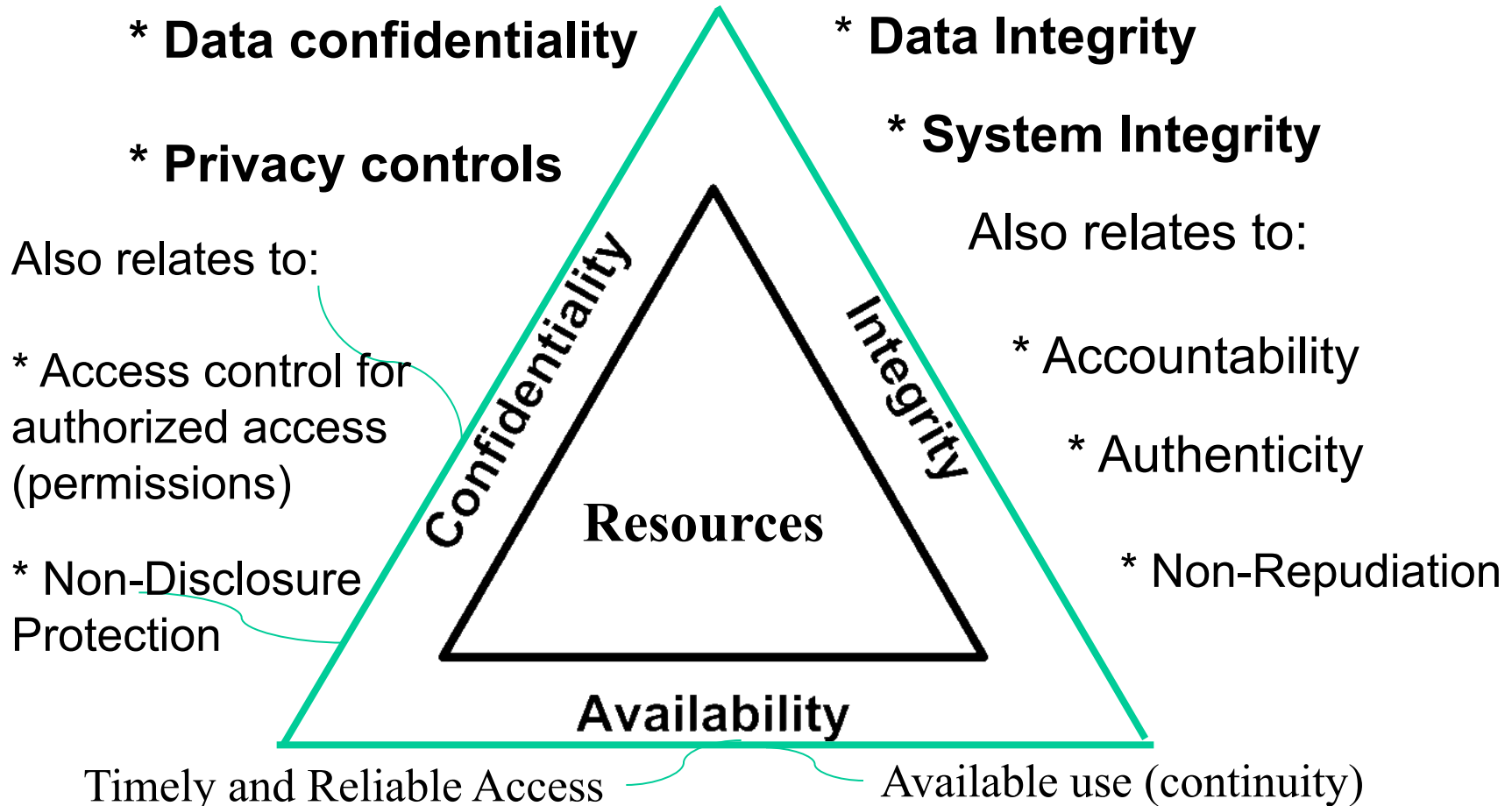
Also Ref. in

FIPS PUB 199

<https://nvlpubs.nist.gov/nistpubs/fips/nist.fips.199.pdf>

C.I.A Triad: FIPS PUB 199 (NIST)

Security properties as main objectives



Resources: Hardware, software, firmware, information/data processing (computation services) and Communications (data flows transmitted on communication channels)

Confidentiality

Data confidentiality: Assures that private or confidential information is not made available or disclosed to unauthorized individuals.

Privacy: Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

Preservation of **authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.**

Loss of confidentiality => unauthorized disclosure of data/information.

Integrity

Data integrity: Assures that information are changed only in a specified and authorized manner and there are means to detect incorrect/illicit modification

System integrity: Assures that a system performs intended functions correctly, e.g. in an unimpaired manner, being free from deliberate or inadvertent unauthorized manipulation of the system (runtimes and their supported executable processes).

Protection against improper information modification or destruction, including ensuring accountable information for non-repudiation and authenticity.

Loss of integrity => unauthorized modification or destruction of information.

Availability

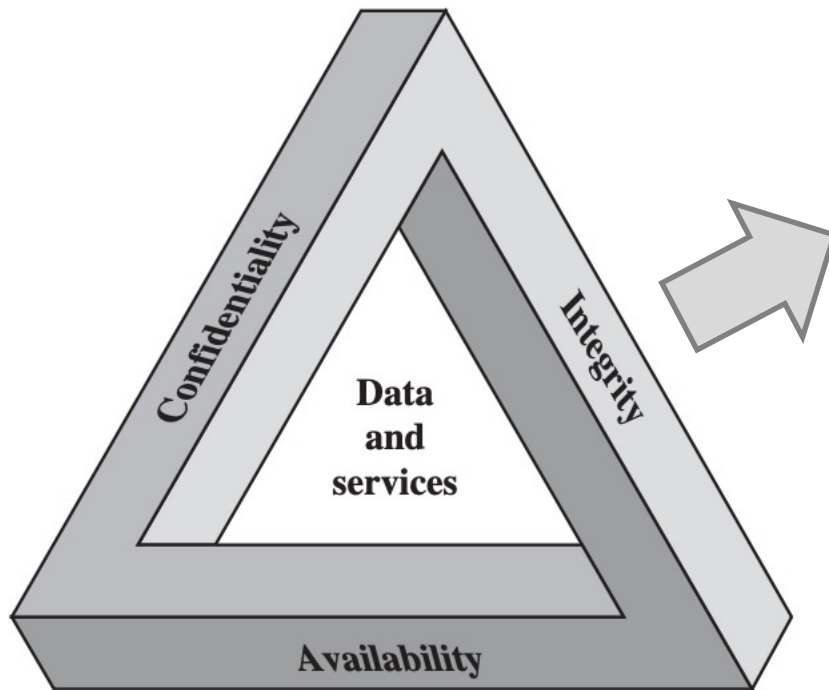
Assures the protection of systems in order to perform promptly, providing services not denied to authorized users, whenever needed

Related to guarantees for timely and reliable access to and use of information/resources.

Loss of availability => disruption of access to or use of information or system resources, causing Denial of Service

Extended properties as key-objectives

The use of the CIA triad to define security objectives is well established, but other additional concepts are also needed for a complete picture.



- **Authenticity (or Authentication)**
 - **Data-Authentication**
 - **Peer (or Entity or Subject) Authentication**
- **Authorization (or access-control)**
- **Accountability**
- **No Repudiation**

The assurance that a principal, data, or software is genuine relative to expectations arising from appearances or context.

Two facets are usually considered:

- **Peer, Subject or Entity Authentication**
 - Guarantees that the identity of a principal involved (ex., in a transaction, message or transmitted data) is as asserted;
- **Data origin authentication** (which may be shortened to **data authentication**)
 - Guarantees that the source of data or software is as asserted; usually in combination of data integrity (above).
- Considering the authentication of software (when installing or loading for execution) addressing the authenticated source/origin together with software integrity, this is the base for **software attestation** (that may be local or remote attestation)

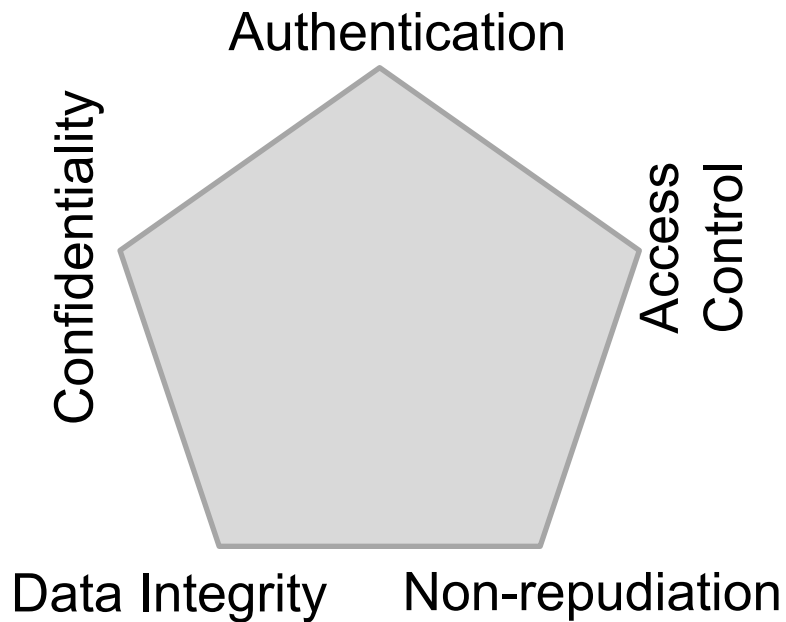
- Authorization (authorized access): property of computing resources being accessible only by authorized entities
 - e.g., those approved w/ necessary permissions by a resource owner (or system administrator).
- Authorized access is achieved through access control mechanisms:
 - Restricting access to physical devices, software services, data/information (or resources in general)
 - implementing **access control policies** under a certain **access control model (MAC, DAC, RBAC, ABAC or CBAC)**

- Is the ability to identify principals responsible for past (actions).
- As the electronic world lacks conventional evidence (e.g., paper trails, human memory of observed events), accountability is achieved by transaction evidence persistent registrations or logging, recorded by electronic or digital means
- Logs must include identifiers of principals involved and all information required for auditing or forensics purposes
- Then, principals cannot later credibly deny (repudiate) previous commitments or conducted actions.

- Registration Logging & Auditing Trails of all events and actions of entities, traced and preserved under integrity guarantees:
 - Non repudiable
 - Deterrence
 - Faults, errors, critical events, actions under security conditions
 - Isolation
 - Events from Intrusion Prevention, Intrusion Detection, Intrusion Tolerance, Recovery actions
 - All data and event notifications relevant for legal, ethical and compliance auditing
- Required and relevant support for security forensics analysis and systems' maintainability

- **Non-repudiation:** a security property that ensures that an entity cannot deny the authenticity and evidence of their actions, communications, or commitments.
- In simpler terms provides **proof of origin** (who did it), **proof of integrity** (that the data wasn't altered) or **proof-of-action** (what was done)
- Non-repudiation is usually combined with the authentication and accountability guarantees. It prevents someone from later saying, *"I didn't send that message,"* or *"I didn't sign that transaction."*, *I didn't modify this file", I didn't install this program", etc.*
- Ex., in a communication protocol performed by two peers, non-repudiation of messages is many times an important property. We can have
 - Non-Repudiation of origin (or sender)
 - Non-Repudiation of destination (or receiver)
 - Mutual authentication

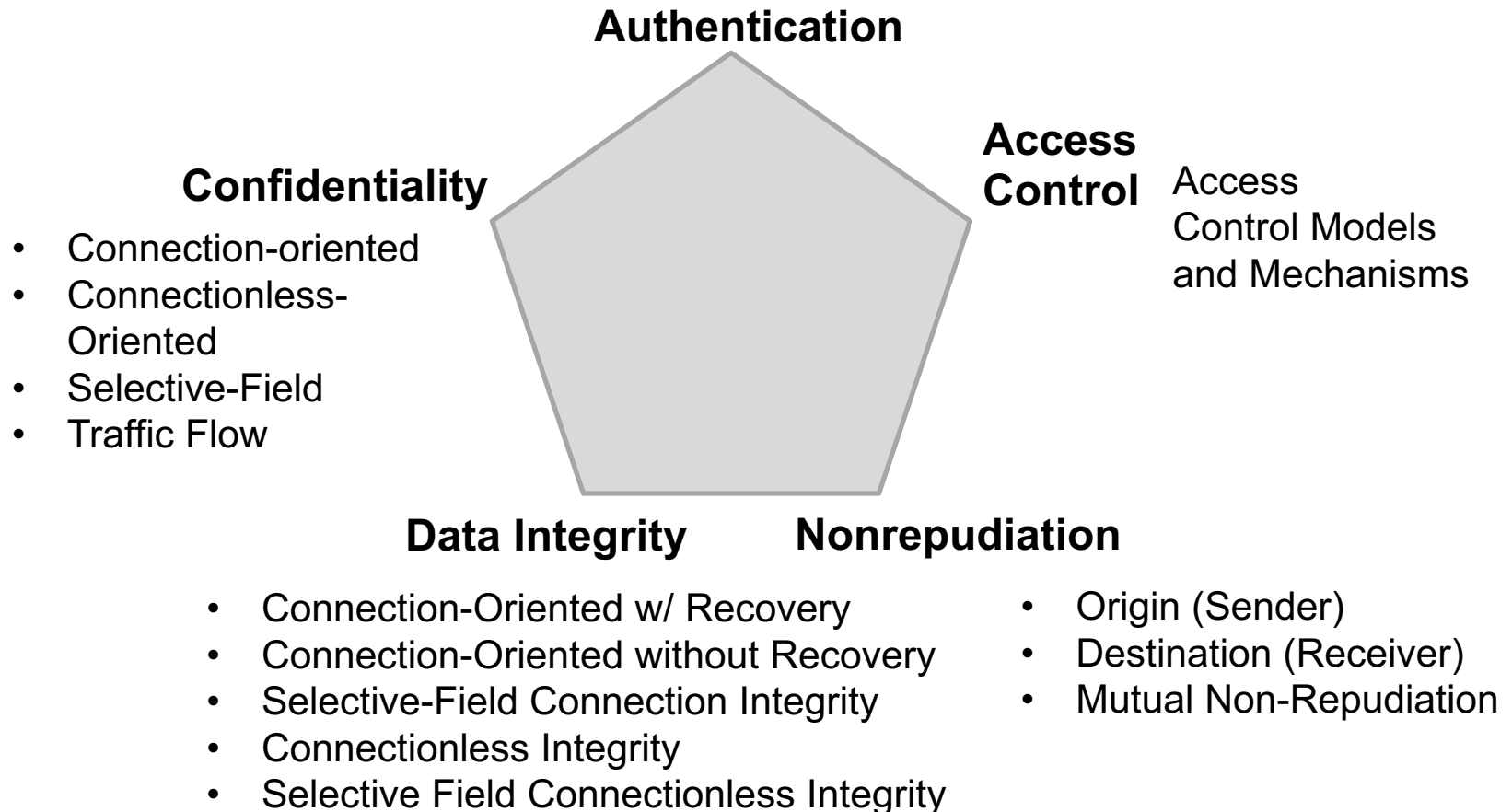
Objectives of preserving security properties, particularly targeted to protect communications



OSI X.800
Framework

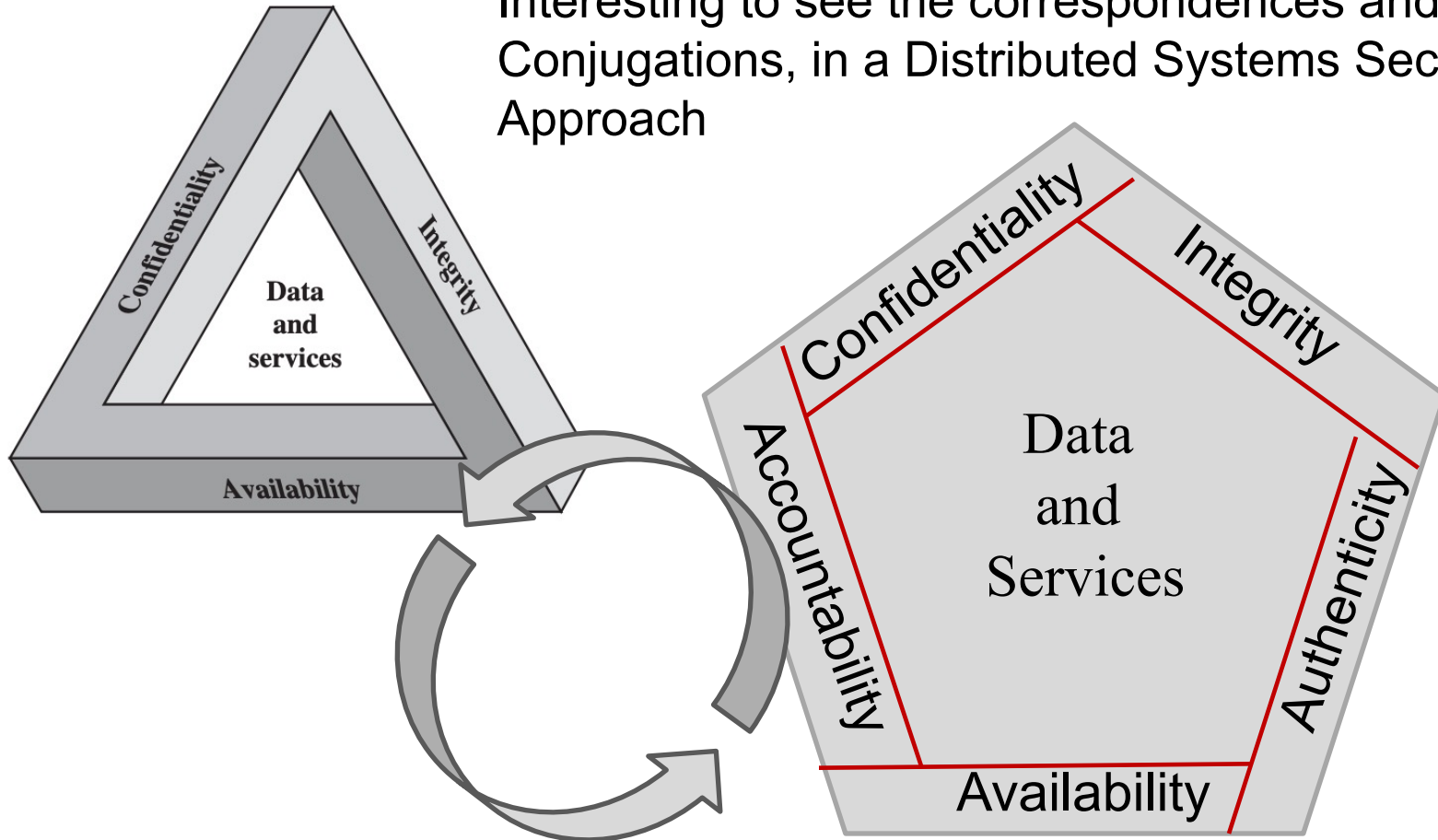
<https://www.itu.int/rec/t-rec-x.800/en>

- Peer-Authentication
- Data-Origin (or Message) Authentication



Ref. on Stallings & Brown, Computer Security Principals and Practice

Interesting to see the correspondences and
Conjugations, in a Distributed Systems Security
Approach



Computer Systems
Security

Network Security

Systematic Approach for Computer Systems and Network Security by Design

A Systematic Approach

Establish Secure Design Principles

Business and Organizational Requirements
Functional and Non-Functional or Architectural
Requirements
Risk Management



Define the Adversary Model
(Threats, Threat Agents, Risk, Attacks Typology, Attack
Vectors and Exploits)

Establish Secure Operation &
Management Requirements

A Systematic Approach

Establish Secure Design Principles

Adversary Model Definition
(Hypothesis, Threats, Risk, Attacks Typology, Attack Vectors)

Define the Security Objectives (countermeasures)

Define and Establish the Security Properties

Design the Security Services
(Ex., Functions, Controls, Protocols)

Implement the security services with correct and verifiable security mechanisms (as building blocks)

Specific Mechanisms

Pervasive Mechanisms

Define the Trust Computing Base

Establish Secure Operation &
Management Requirements

Using correct definitions, terminology and starting from well established concepts and notions, for:

- The definition of the adversary model, from attack types, attack vectors and attack surfaces
- The definition of security services from required security properties
- The definition of security mechanisms used and their verifiable security guarantees (as building blocks) to support the security services
- The identification, delimitation, minimization and confinement (isolation) of TCB Assumptions

Good idea: Use knowledge bases from Security Frameworks and Standards (as Referential Knowledge Bases))

Other security frameworks

- Well known/accepted standard knowledge bases, addressing terminology, concepts, definitions and related security standards
 - Several technical/engineering frameworks ☹, Ex:
 - **FIPS PUB 199 (FIPS / NIST Secure Standards)**
 - **IETF RFC 4949 (IETF Internet Security Standards & RFCs)**
 - **IETF Internet Security Glossary for IETF Security Standards**
 - **OSI X.800 (Conceptual OSI Reference), ITU**

- ISO (ex., 17999 and 27000 series) – more relevant for “Organizational Security” and Security/Cybersecurity management, auditing, monitoring of information systems’ resources and related assets, as well as, for security certification purposes (see <https://www.27001.pt/>)
- In general, frameworks relate to extensive documentations ... ☹

- OSI X.800:
 - <https://www.itu.int/rec/T-REC-X.800-199103-I>
- FIPS PUB 199:
 - <https://nvlpubs.nist.gov/nistpubs/fips/nist.fips.199.pdf>
- IETF RFC 4848
 - <https://www.rfc-editor.org/rfc/rfc4949>
- ISO 27000 Series
 - <https://www.iso.org/standard/73906.html>
- ISO 27001 (Information Security Management)
 - <https://www.iso.org/isoiec-27001-information-security.html>

Example of other relevant references

Examples:

GRC: Governance,
Regulation and Compliance

- HIPAA
- GDPR
 - EU: <https://gdpr.eu/what-is-gdpr/>
 - US:
- CCPA California Consumer Privacy ACT
 - <https://oag.ca.gov/privacy/ccpa>
- EU Cybercrime ACT
 - <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-act>
- LAW, ex:
 - PT: Cybercrime Law (Dec. Lei 109/2009)
 - See also <https://cibercrime.ministeriopublico.pt/en>
 - CNPD <https://www.cnpd.pt/>

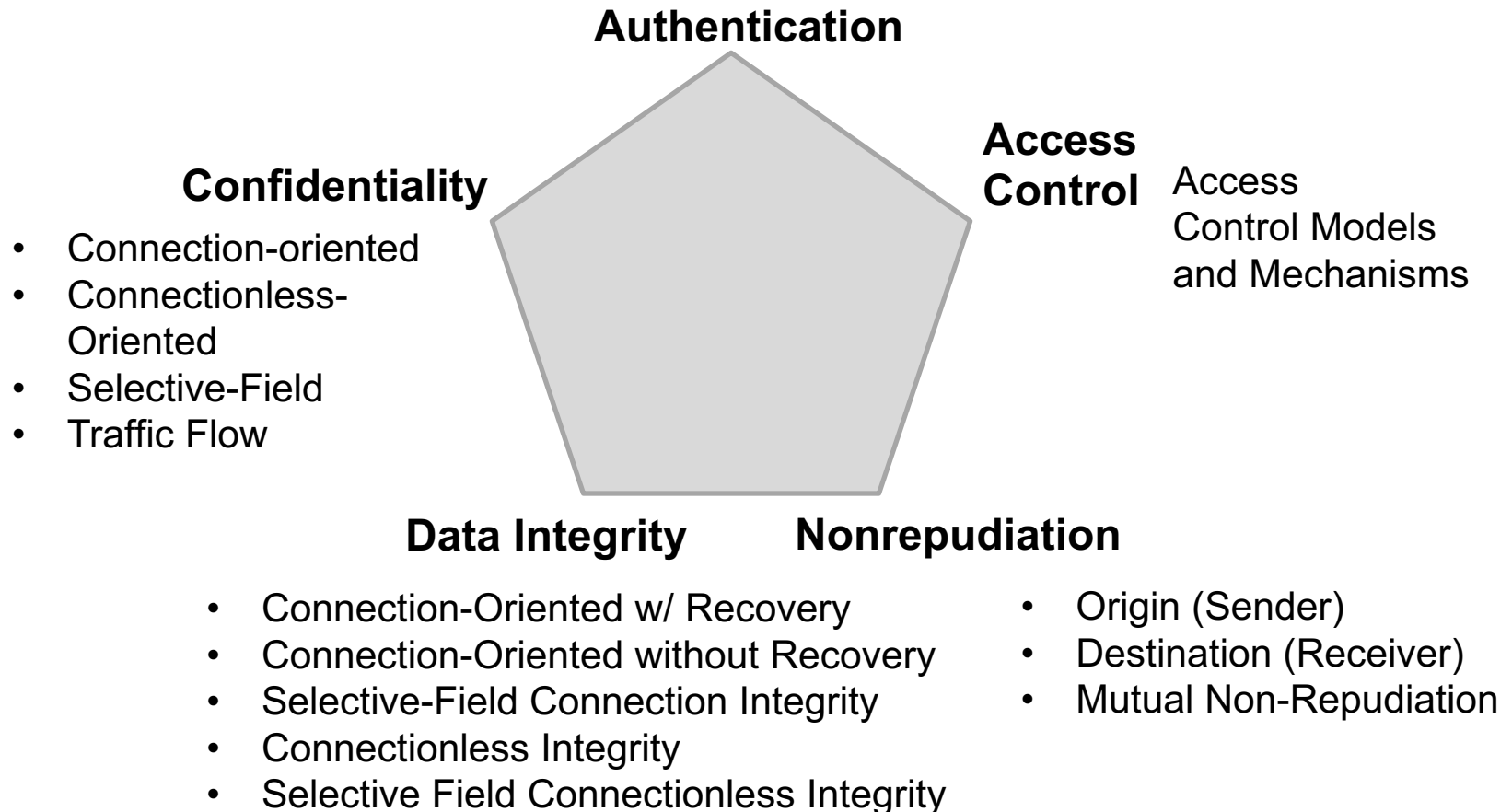
OSI X.800

Concepts, notions and terminology

From Attack Types to Security Properties, Security Services and Security Mechanisms

- Concepts and mappings commonly used, ex:
 - OSI X.800 System Architecture
 - Net Security, Internet Security
 - IETF RFC 4949
- Stallings, Network Security Essentials, Chap.1, Suggested Readings on:
 - OSI Architecture
 - What is threat and what is attack
 - What is a security mechanism
 - What are pervasive vs. specific mechanisms
 - What are active vs. passive attacks

- Peer-Authentication
- Data-Origin (or Message) Authentication



X.800 defined *Security Services* (1)

AUTHENTICATION

The assurance that the communicating entity is the one that it claims to be.

Peer Entity Authentication

Used in association with a logical connection to provide confidence in the identity of the entities connected.

Data-Origin Authentication

In a connectionless transfer, provides assurance that the source of received data is as claimed.

DATA CONFIDENTIALITY

The protection of data from unauthorized disclosure.

Connection Confidentiality

The protection of all user data on a connection.

Connectionless Confidentiality

The protection of all user data in a single data block.

Selective-Field Confidentiality

The confidentiality of selected fields within the user data on a connection or in a single data block.

Traffic-Flow Confidentiality

The protection of the information that might be derived from observation of traffic flows.

X.800 defined *Security Services* (2)

DATA INTEGRITY

The assurance that data received are exactly as sent by an authorized entity (i.e., contain no modification, insertion, deletion, or replay).

Connection Integrity with Recovery

Provides for the integrity of all user data on a connection and detects any modification, insertion, deletion, or replay of any data within an entire data sequence, with recovery attempted.

Connection Integrity without Recovery

As above, but provides only detection without recovery.

Selective-Field Connection Integrity

Provides for the integrity of selected fields within the user data of a data block transferred over a connection and takes the form of determination of whether the selected fields have been modified, inserted, deleted, or replayed.

Connectionless Integrity

Provides for the integrity of a single connectionless data block and may take the form of detection of data modification. Additionally, a limited form of replay detection may be provided.

Selective-Field Connectionless Integrity

Provides for the integrity of selected fields within a single connectionless data block; takes the form of determination of whether the selected fields have been modified.

NONREPUDIATION

Provides protection against denial by one of the entities involved in a communication of having participated in all or part of the communication.

Nonrepudiation, Origin

Proof that the message was sent by the specified party.

Nonrepudiation, Destination

Proof that the message was received by the specified party.

- Authentication

- Peer Authentication (or Principals or Subjects Authentication)
- Mutual vs. Unilateral Authentication
- Data Origin Authentication
- Message Authentication

- Access Control

- Prevention of access to unauthorized (nor permissioned) resources
 - Models: ex, MAC, RBAC, ABAC, CBAC models

- Data & Data-Flows Confidentiality

- Connection-Oriented Confidentiality
- Connectionless Confidentiality
- Selective-Field Confidentiality
- Traffic Flow Confidentiality

- Data Integrity

- Connection-Integrity w/ Recovery
- Connection-Integrity without recovery
- Selective-Field Connection Integrity
- Connectionless Integrity
- Selective-Field Connectionless Integrity

- Nonrepudiation

- Non-Repudiation of Origin
- Non-Repudiation of Destination
- Mutual non-repudiation

Emphasis on Attacks against Communication Channels (“**On-Channel** and **Man-In-The-Middle Adversaries**”)

Passive Attacks

- Release of Message Contents (Message Disclosure, Eavesdropping, Message/Packet/Datagram/Frames captures and inspections w/ specific layering or stateful layer inspection approach)
- Traffic Analysis

Active Attacks

- Masquerading
- Spoofing (also related to Sybil Attacks)
- Modification of messages (Message Tampering)
- Replaying or Message Replaying
- Message Forging
- Message dropping (Interruption)
- Denial of Service (DoS)

- **Passive attacks:** don't affect/modify state
 - Easy to defend, difficult to detect ... Why ?
 - Many times, not detectable or silent attacks
- **Active attacks:** affect/modify state
 - Can have (not always) simple detection of anomalous correct state deviations (ex., verifiable state-machines in endpoints) or detectable incorrect traffic patterns
 - Difficult to defend (if attacks against the endpoints or expected processing state are possible and we don't have countermeasures for timely intrusion recovery or intrusion tolerance)

Example in defining a secure channel

- A communication channel on top of transport protocol (ex., TCP) providing countermeasures for immunity against well defined attack types (ex., using X.800 attack types), supporting the following security properties:
 - Mutual peer authentication
 - Message authentication
 - Message integrity
 - No message replaying
 - Traffic flow integrity
 - Message confidentiality
 - Connection oriented integrity with recovery
 - Mutual non-repudiation of sent/received messages
 - Access control

- Anonymity and Privacy Preservation
 - Anonymity of peers (anonymous identifiers)
 - Privacy-Preserved Communication
 - Anonymous communication
 - Anonymous traffic flows
 - Traffic blockage avoidance
 - Censorship circumvention
 - WHAT PROTECTION MECHANISMS AND TECHNIQUES
- Accountability
 - Logging and auditing services
 - Security events (forensic analysis)

OSI X.800:

Specific Mechanisms

- Security Mechanisms: as building blocks to support security services

SPECIFIC SECURITY MECHANISMS

May be incorporated into the appropriate protocol layer in order to provide some of the OSI security services.

Encipherment

The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.

Digital Signature

Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery (e.g., by the recipient).

Access Control

A variety of mechanisms that enforce access rights to resources.

Data Integrity

A variety of mechanisms used to assure the integrity of a data unit or stream of data units.

Authentication Exchange

A mechanism intended to ensure the identity of an entity by means of information exchange.

Traffic Padding

The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.

Routing Control

Enables selection of particular physically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.

Notarization

The use of a trusted third party to assure certain properties of a data exchange.



Cryptography (Alg.,
Methods, Models,
Techniques:
Used as foundational
(verifiable) specific
mechanisms

Specific vs. Pervasive Security Mechanisms

- Security Mechanisms: as building blocks to support security services

PERVASIVE SECURITY MECHANISMS

Mechanisms that are not specific to any particular OSI security service or protocol layer.

Trusted Functionality

That which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).

Security Label

The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.

Event Detection

Detection of security-relevant events.

Security Audit Trail

Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.

Security Recovery

Deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.



Can see Operational Security mechanisms (for operational security services), as pervasive mechanisms

Security Properties vs. Security Mechanisms

Mechanism

Service	Encipherment	Digital Signature	Access Control	Data Integrity	Authentication Exchange	Traffic Padding	Routing Control	Notarization
Peer Entity Authentication	Y	Y			Y			
Data-Origin Authentication	Y	Y						
Access Control			Y					
Confidentiality	Y						Y	
Traffic-Flow Confidentiality	Y					Y	Y	
Data Integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			

Specific Security Mechanisms

- Encipherment (Encryption)
- Digital Signatures
- Data Integrity
- Authentication Exchanges
- Access Control
- Traffic Padding
- Routing Control
- Notarization

Cryptographic Algorithms,
Methods and Techniques

Pervasive Security Mechanisms

- Trusted Mechanisms imposed by Security Policy Enforcement
- Security Labels for Security Attributes
- Event Detection
- Security Audit Trails
- Security Recovery

Mapping Attacks vs. Security Services

Attack Typology: Network Attack Types

Security Services	Release of message contents	Traffic analysis	Masquerade	Replay	Modification of messages	Denial of service
Peer entity authentication			Y			
Data origin authentication			Y			
Access control			Y			
Confidentiality	Y					
Traffic flow confidentiality		Y				
Data integrity				Y	Y	
Non-repudiation			Y			
Availability						Y

Mapping Attacks vs. Security Mechanisms

Attack Typology

Security Mechanisms	Release of message contents	Traffic analysis	Masquerade	Replay	Modification of messages	Denial of service
Encipherment	Y					
Digital signature			Y	Y	Y	
Access control	Y	Y	Y	Y		Y
Data integrity				Y	Y	
Authentication exchange	Y		Y	Y		Y
Traffic padding		Y				
Routing control	Y	Y				Y
Notarization			Y	Y	Y	

Security services vs. Security Mechanisms

NOVA SCHOOL OF
SCIENCE & TECHNOLOGY

Security Mechanisms

Mechanism

Security Services

Service	Enciph- erment	Digital signature	Access control	Data integrity	Authenti- cation exchange	Traffic padding	Routing control	Notari- zation
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y						Y	
Traffic flow confidentiality	Y					Y	Y	
Data integrity	Y	Y		Y				
Non-repudiation		Y		Y				Y
Availability				Y	Y			

Big Picture (X.800 mappings)

	Release of message contents	Traffic analysis	Masquerade	Replay	Modification of messages	Denial of service
Peer entity authentication			Y			
Data origin authentication			Y			
Access control			Y			
Confidentiality	Y					
Traffic flow confidentiality		Y				
Data integrity				Y	Y	
Non-repudiation			Y			
Availability						Y

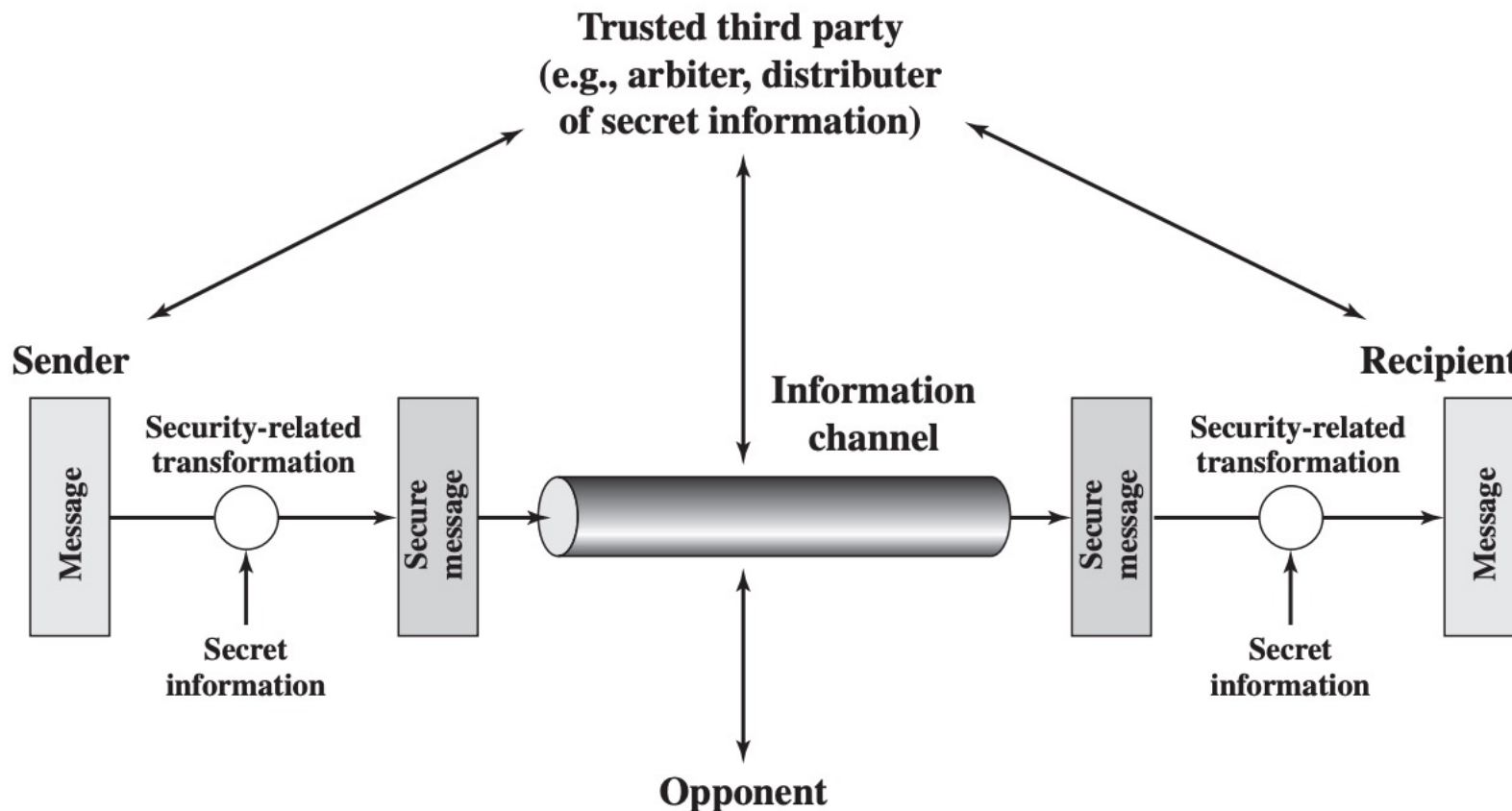
	Release of message contents	Traffic analysis	Masquerade	Replay	Modification of messages	Denial of service
Encipherment	Y					
Digital signature			Y	Y	Y	
Access control	Y	Y	Y	Y		Y
Data integrity				Y	Y	
Authentication exchange	Y		Y	Y		Y
Traffic padding		Y				
Routing control	Y	Y				Y
Notarization			Y	Y	Y	

**Cryptography methods,
Algorithms, models, techniques**

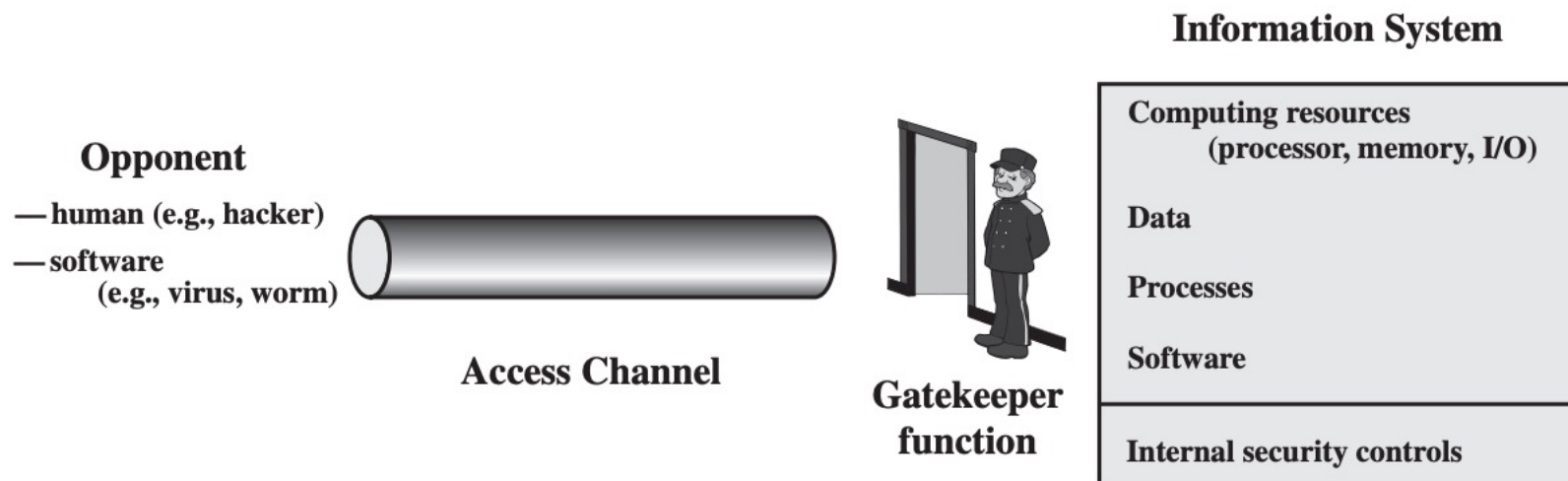
Service	Mechanism							
	Encipherment	Digital signature	Access control	Data integrity	Authentication exchange	Traffic padding	Routing control	Notarization
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y						Y	
Traffic flow confidentiality	Y					Y	Y	
Data integrity	Y	Y		Y				
Non-repudiation		Y		Y				Y
Availability				Y	Y			

Concretization of Computer Systems and Network Security (Layering and Layered Security Services)

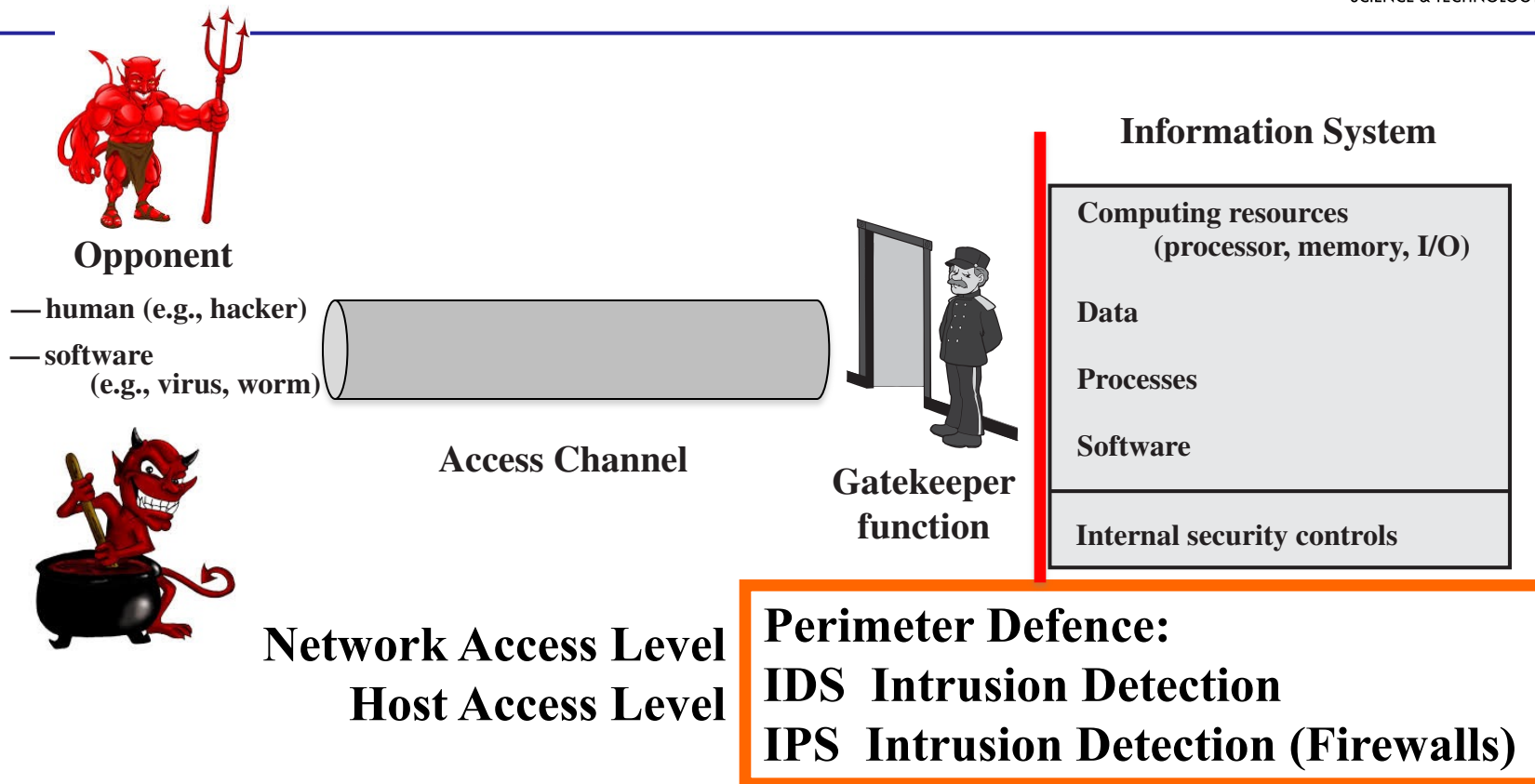
Network Security Model



Network Access Model



Network Access Security Model



Networks and Perimeter Defence

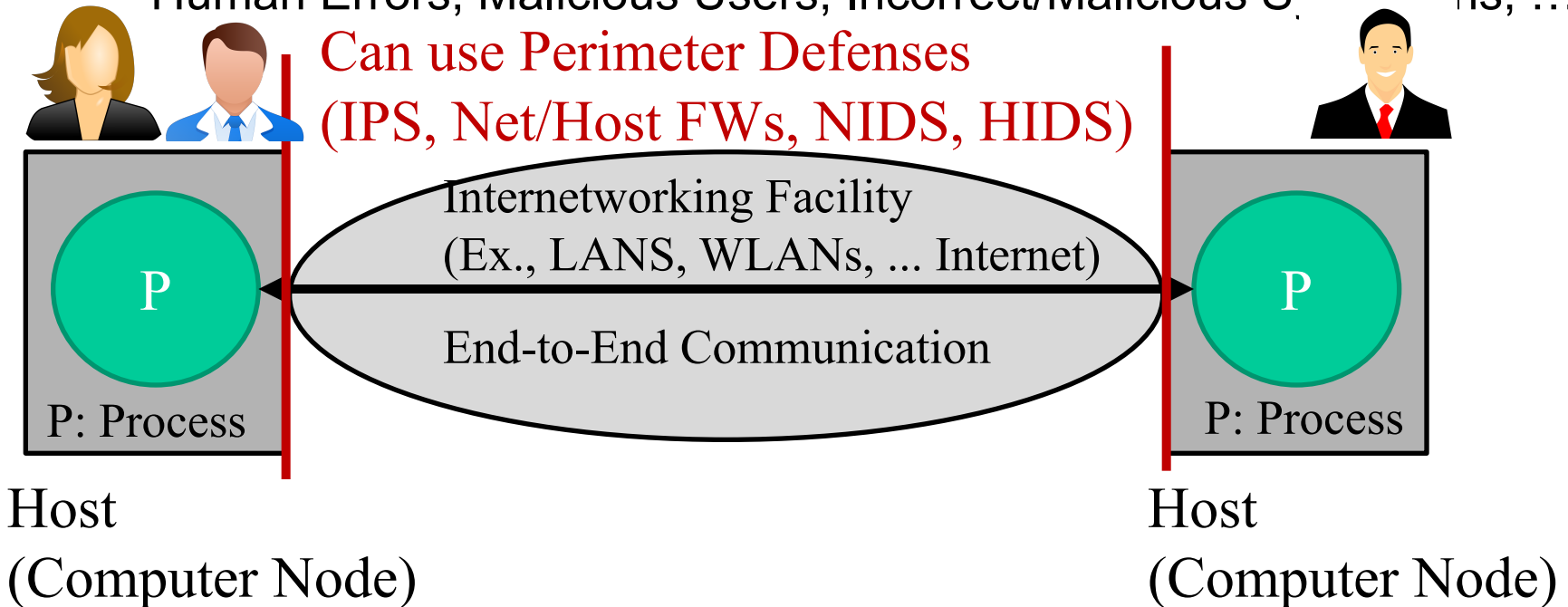
Segregation of network segments
Switches, Routers
NIPS: Net Firewalls
Network Based Intrusion Detection
Systems (NIDS)

Nodes and Perimeter Defence

OS and Application-Level
Firewalls (FWs)
Host-Based Intrusion Detection
(HIDS)

Countermeasures against attacks

- Attacks against Communication Resources
 - Network-targeted attacks
- Attacks against Computer Systems' Resources
 - Attacks against Users (or Users as Adversaries)
 - Human Errors, Malicious Users, Incorrect/Malicious Specifications, ...



Distributed Systems vs. Computer Systems and Network Security

- Distributed Systems
 - Processing nodes (computer nodes w/ local autonomous resources) interconnected and interacting by communication channels (network)
 - Distributed System Model Abstractions
 - Graph (nodes and edges) and graph properties
 - Processes (nodes)
 - Correct vs. Incorrect States, Fault Models, Intrusion models
 - State transitions, input and output events
 - Processes formally modeled by algorithms
 - Links (edges)
 - Link properties (security, reliability, availability and maintainability conditions and guarantees)

Distributed Systems vs. Computer Systems and Network Security

- Computer systems and network security approach
 - Computer nodes
 - Software Stacks
 - Layers of Processing Services supported by Firmware/Hardware
 - Possible multilayering and/or composable processing stacks
 - Network
 - Protocol stacks (application level, session-data representation level, transport level, network level, data-link level, physical-support level)
 - Particularly interesting: Internet communication protocol stacks (TCP/IP protocols and services)

TRUSTED VS. TRUSTWORTHY.

Terms *trusted* and *trustworthy*:

- Something is trustworthy if it *deserves* our confidence, i.e., will reliably meet expectations.
- Something trusted *has* our confidence, whether deserved or not;
- So, a trusted component is relied on to meet expectations, but if it fails then all guarantees are lost.
- For example, if we put money in a bank, we trust the bank to store and return it.
- A bank that has, over 500 years, never failed to return deposits would be considered trustworthy; one that goes bankrupt after ten years may have been trusted, but was not trustworthy.

CONFIDENTIALITY vs. PRIVACY.

- Confidentiality involves information protection to prevent unauthorized disclosure.
- A related term, *privacy* (*information privacy*), more narrowly involves *personally sensitive* information (as owned information or data), protecting it, and controlling how it is shared and what is the propose or finality.
- An individual may suffer anxiety, distress, reputational damage, discrimination, or other harm upon release of their home or email address, phone number, health or personal tax information, political views, religion, sexual orientation, consumer habits, or social acquaintances.
- What information should be private is often a personal choice, depending on what an individual desires to selectively release.

PRIVACY vs. ANONYMITY

- In some cases, privacy is related to anonymity — the property that one's actions or involvement are not linkable to a public identity.
- While neither privacy nor anonymity is a main focus in our course, many of the security mechanisms we discuss are essential to support both.
- Sometimes, authentication w/ identification creates a tension not supporting anonymity. However, we can address authentication (ex., authentication of transactions) under anonymous (or pseudo-anonymous) identifiers of involved peers. The same for anonymization of network access/communication (ex., Internet)

Bibliography Roadmap

- Notion of “Principal”, “Subject” or “Peer”, and their levels of abstraction
- Vulnerability vs. Threat vs. Attack vs. Incident
 - Passive Attacks vs. Active Attacks
 - Inside attacks vs. outside attacks
 - Typology of attacks
- Security Assets
- Risk (R) vs. Threats (T) vs. Vulnerabilities (V) vs. Asset-Value (V)
$$R = T \times V \times V$$
$$R(t) = T(t) \times V(t) \times V(t)$$
- Risk Assessment and Modeling

Bibliography Roadmap

- Trust Computing Base (or TCB)
 - How to deal w/ Trusted Computing Bases
- Threat model and adversary model definition
- Attack Surfaces and Attack Trees
- Initial approach for computer systems security model (or Distributed Systems Security Approach)
- Perimeter Defenses vs. In Deep-Defenses
- Security Functional Requirements
- Fundamental Design Principles for Computer Security

Questions / Discussion

Suggested Readings

- Review the slides ...
- W. Stallings, L. Brown, Computer Security – Principles and Practice, Person, Ch.1
- W. Stallings, Network Security Essentials – Applications and Standards, Ch.1



- Peter C. van Oorschot, Computer Security and the Internet, 2nd Edition, Chap. 1 - Security Concepts and Principles, Springer 2021
- <https://people.scs.carleton.ca/~paulv/toolsjewels.html>

